

Klausur / Exam

Grundlagen der IT-Sicherheit /

Foundations of IT Security

H T
W I
G N

Prof. Dr. Hanno Langweg

2025-01-27T0800 – 2025-01-27T0930

- 14 Blätter einschließlich Deckblatt / *14 pages including this front page*
- Bearbeitungsdauer: **90 Minuten** / *Available time 90 minutes*
- Zugelassene Hilfsmittel: Keine
No permitted examination aids
- Schreiben Sie Ihre Matrikelnummer auf **jede** Seite
*Write your student number on **each** page*
- Benutzen Sie nur das Klausurpapier (Rückseite, wenn nötig)
Use only paper handed out (use reverse side of page if necessary)
- Schreiben Sie **lesbar**. Verwenden Sie einen schwarzen oder blauen Stift, keinen roten oder grünen.
Write legibly. Use a black or a blue pen, do not use a red or a green one.

Vorname: _____
Given name

NACHNAME: _____
Family name

Matrikelnr.: _____
Student number

☐

AIN

☐

WIN

☐

Anderer Studiengang

Study programme

(other)

Regelmäßige Teilnahme an der Lehrveranstaltung in diesem Semester: ☐ ja ☐ nein

I attended classes regularly during the semester:

yes no

Allen, die gelernt
haben, wünsche ich
viel Erfolg und allen
anderen viel Glück!

Good luck!

1. Schadsoftware / Malware (6+2 = 8)
2. Positivlisten / Whitelisting (6+2+4 = 12)
3. Risikobewertung / Risk Assessment (2+2 = 4)
4. Authentifizierung / Authentication (6+2 = 8)
5. Zugriffssteuerung / Access Control (8+2+4 = 14)
6. IT-Grundschutz / IT Base Protection (1+1+1 = 3)
7. Schwachstellen / Vulnerabilities (2+2 = 4)
8. Statische Codeanalyse / Static Code Analysis (1+4+2 = 7)
9. Lieferkettenangriffe / Supply Chain Attacks (2+2 = 4)
10. Microsoft SDL (2+2+1 = 5)
11. Zertifizierung / Certification (2+3+6+1 = 12)
12. Kryptographie / Cryptography (2+1+1+1+1+2+1 = 9)

1. Schadsoftware / Malware (6+2 = 8)

- a) Beschreiben Sie die drei üblichen Verfahren, wie Virens Scanner Malware erkennen und vergleichen Sie die Verfahren zusätzlich in den Dimensionen Genauigkeit, Geschwindigkeit und Effizienz.

Describe the three common approaches how virus scanners detect malware and in addition discuss the approaches in terms of accuracy, speed, and efficiency.

- b) Beschreiben Sie Ransomware mit Bezug auf Verbreitungsmethode und Schadfunktionalität.

Describe ransomware with respect to propagation and payload.

2. Positivlisten / Whitelisting (6+2+4 = 12)

- a) Nennen Sie drei Arten, auf die Sie festlegen können, welche Dateien in eine WDAC-Positivliste aufgenommen werden. Geben Sie für jede der drei Arten Vor- und Nachteile an.

Name three ways to specify which files are included in an application whitelist for WDAC. State advantages and disadvantages for each of the three ways.

- b) Wozu dient der Audit Mode bei WDAC?

What is the purpose of the audit mode of WDAC?

c) Windows Defender Application Control (WDAC)

Kreuzen Sie alle richtigen und nur die richtigen Antworten an.

Mark all correct answers and only correct answers.

- ☐ Eine pfadbasierte Positivliste in WDAC nennt man Fähigkeitsliste.
A path-based application whitelist in WDAC is called a capability list.
- ☐ Eine pfadbasierte Positivliste in WDAC gibt an, in welchen Verzeichnissen eine Anwendung Daten lesen darf.
A path-based application whitelist in WDAC specifies to which directories an application is allowed to read.
- ☐ Eine pfadbasierte Positivliste in WDAC gibt an, in welchen Verzeichnissen eine Anwendung Daten schreiben darf.
A path-based application whitelist in WDAC specifies to which directories an application is allowed to write.
- ☐ Eine pfadbasierte Positivliste in WDAC gibt an, in welchen Verzeichnissen Dateien ausgeführt werden dürfen.
A path-based application whitelist in WDAC specifies in which directories files are allowed to be executed.
- ☐ Eine Positivliste in WDAC wird als Restricted SID in einem Token gespeichert.
An application whitelist in WDAC is stored as a restricted SID in a token.
- ☐ Eine pfadbasierte Positivliste in WDAC kann mit einer zertifikatbasierten Positivliste kombiniert werden.
A path-based application whitelist in WDAC can be combined with a certificate-based application whitelist.
- ☐ Eine Positivliste in WDAC wird auf gewöhnliche Benutzerkonten angewendet.
An application whitelist in WDAC is applied to ordinary user accounts.
- ☐ Eine Positivliste in WDAC wird auf Benutzerkonten von Systemadministratoren angewendet.
An application whitelist in WDAC is applied to user accounts of system administrators.

3. Risikobewertung / Risk Assessment (2+2 = 4)

Was sind die zwei Variablen in der Risikobewertung? Was macht die Bewertung einfacher oder schwerer bezogen auf die beiden Variablen?

What are the two variables in risk assessment? What makes the assessment easier or harder with respect to these two variables?

4. Authentifizierung / Authentication (6+2 = 8)

Was sind die drei Arten der Benutzerauthentifizierung?

What are the three categories of user authentication?

Was versteht man unter Zwei-Faktor-Authentifizierung?

What is meant by two-factor authentication?

5. Zugriffssteuerung / Access Control (8+2+4 = 14)

- a) Erläutern Sie den Unterschied zwischen Tokens und Zugriffssteuerungslisten in Microsoft Windows. Nutzen Sie in Ihrer Erläuterung die Begriffe SID, Privileg (eingedeutscht „Benutzerrecht“), ACE.

Explain the difference between tokens and access control lists in Microsoft Windows. Use the terms SID, privilege, and ACE in your explanation.

- b) Benutzerrechte in Windows

Privileges in Windows

Nennen Sie zwei systemweite Benutzerrechte (Privilegien), welche es bei Zuweisung einem Benutzerkonto ermöglichen, die Zugriffssteuerung mittels Zugriffssteuerungslisten (ACLs) zu umgehen. Begründen Sie Ihre Wahl.

Name two system-wide privileges that when assigned enable a user account to circumvent access control with access control lists (ACLs). Justify your choice.

c) Inhalt von Strukturen der Zugriffssteuerung

Content of structures in access control

Gegeben sei folgende Zugriffssteuerungsmatrix:

Consider the following access matrix:

	TikTok	BeReal	BlueMail	Maps
Pictures				
Music	RW	RW		
Contacts	RW	RW	R	R
Location	R	R		R

Schreiben Sie alle nichtleeren Zugriffssteuerungslisten auf.

Write down all nonempty access control lists.

Schreiben Sie alle nichtleeren Fähigkeitslisten auf.

Write down all nonempty capability lists.

6. IT-Grundschutz / IT Base Protection (1+1+1 = 3)

Erklären Sie den Unterschied zwischen Basis-Absicherung, Kern-Absicherung und Standard-Absicherung nach IT-Grundschutz.

Explain the difference between basic protection, core protection, and standard protection according to IT-Grundschutz.

7. Schwachstellen / Vulnerabilities (2+2 = 4)

- a) Welchen Nutzen haben Datenbanken mit Daten über Softwareschwachstellen für den IT-Betrieb (z.B. die NVD National Vulnerability Database)?

What is the benefit in IT operations of using a database containing data about known software vulnerabilities (e.g. the NVD National Vulnerability Database)?

- b) Wozu dienen CWE-Bezeichner?

What is the purpose of CWE identifiers?

8. Statische Codeanalyse / Static Code Analysis (1+4+2 = 7)

- a) Was bezeichnet man als statische Codeanalyse?

Explain the term static code analysis.

- b) Erläutern Sie die Begriffe „True Positive“, „False Positive“, „True Negative“, „False Negative“ im Kontext der statischen Codeanalyse.

Explain the terms “true positive”, “false positive”, “true negative”, “false negative” in the context of static code analysis.

- c) Wieswegen ist ein hoher Anteil von False Positives problematisch?

Why is a high rate of false positives problematic?

9. Lieferkettenangriffe / Supply Chain Attacks (2+2 = 4)

Was bezeichnet man als Lieferkettenangriff und warum ist das ein Problem in der Softwaresicherheit?

What is a supply chain attack and why is that a problem in software security?

10. Microsoft SDL (2+2+1 = 5)

Wählen Sie drei Praktiken aus Microsofts SDL und erklären Sie diese (aber NICHT: Training, Static Security Testing, Dynamic Security Testing, Penetration Testing).

Pick three practices of Microsoft's SDL and explain them (but NOT: Training, Static Security Testing, dynamic Security Testing, Penetration Testing).

11. Zertifizierung / Certification (2+3+6+1 = 12)

Die Foobar-Software der ACME Corp. hat eine EAL4-Evaluierung nach Common Criteria erfolgreich abgeschlossen.

The Foobar software of ACME Corp. was successfully evaluated at EAL4 according to the Common Criteria product evaluation scheme.

- a) Welche Rolle spielen die Anforderungen an die Einsatzumgebung eines TOE?
What is the role of the objectives for the environment of a TOE?

- b) Was sind Tätigkeiten einer Evaluatorin für die genannten EALs, die nicht bereits für niedrigere EALs verpflichtend sind?
What are specific activities performed by an evaluator at the given EAL that are not mandatory for the lower EALs?

EAL2 (zusätzlich zu / *added activities compared to EAL1*)

EAL3 (zusätzlich zu / *added activities compared to EAL2*)

EAL4 (zusätzlich zu / *added activities compared to EAL3*)

- c) Erläutern Sie das Vorgehen bei der Schwachstellenanalyse AVA_VAN nach Common Criteria.

Explain how a vulnerability analysis AVA_VAN is performed according to Common Criteria.

- d) Wie werden die Fähigkeiten eines Angreifers bzw. einer Angreiferin nach den fünf in der CEM Common Evaluation Methodology genannten Dimensionen bewertet?

How are attacker capabilities assessed according to the CEM Common Evaluation Methodology using the five dimensions mentioned therein?

12. Kryptographie / Cryptography (2+1+1+1+1+2+1 = 9)

- a) Was sind symmetrische und asymmetrische Verschlüsselungsverfahren?
What are symmetric and asymmetric cryptosystems?

- b) Erläutern Sie ein hybrides Verschlüsselungsverfahren.
Explain a hybrid cryptosystem.

- c) Warum ist die Länge eines kryptographischen Schlüssels wichtig?
Why is the length of a cryptographic key important?

- d) Welche minimale Länge wird heutzutage für RSA-Schlüssel empfohlen?
What is the recommended minimum length for RSA keys?

- e) Wo finden Sie verlässliche Informationen über empfohlene Schlüssellängen?
Where do you find reliable information about recommended key lengths?

- f) Der One-Time-Pad ist der sicherste Verschlüsselungsalgorithmus. Warum werden in der Praxis meist weniger sichere Algorithmen verwendet?
The One-Time-Pad is the most secure encryption algorithm. Why are often less secure algorithms used in practice?

- g) Wofür werden Zufallszahlen in der Kryptographie verwendet?
What is the purpose of random numbers in cryptography?
